A-SysArmor在openeuler创新与实践：安全高效国产系统审计框架

主讲人：张涵

研究背景

- **系统审计**（System Auditing）：收集关于系统资源使用数据的过程
  - 系统审计提供了一种记录和分析**各种系统事件**的机制

    进程创建、敏感文件访问、未知IP的网络连接、权限提升等
- **系统审计日志**：记录了产生的系统事件，**具有丰富的应用价值**
  - 可以用于安全调查和补救任务，包括：定期检查主机的健康状况、实时检测各种网络攻击、以及在系统遭到入侵后进行深度分析以找出入侵根源等

t1: httpd spawn bash
t2: bash spawn wget
t3: wget write “malware”
t4: bash reads other files
…
t8: wget write other files
…

System Auditing Logs

美国2021年发布的一项行政命令已经要求所有联邦机器都必须进行系统审计

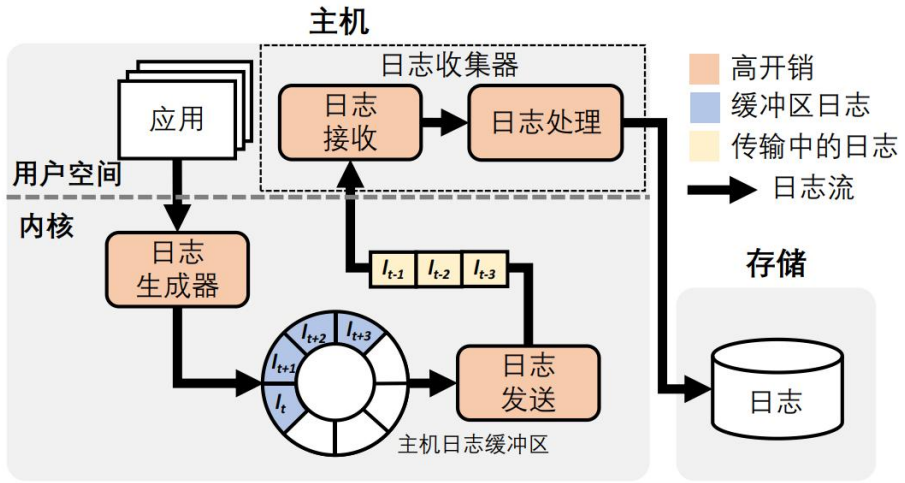
开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

研究背景

➢ 系统审计框架

- 主流操作系统都支持系统审计，提供专门的**系统审计框架**，用于采集审计日志，如 Linux 审计系统 (Linux Auditd) 和 Windows 事件跟踪（ETW）
- 系统审计框架涉及内核和用户空间的交互
  - 内核空间的**日志生成器**对内核函数插桩，获取事件基本信息，并存到**日志缓冲区**
  - 用户空间的**日志收集器** 执行对缓冲区事件的获取、日志格式化以及存储等操作

wget
syscall (write)



审计日志：
t1: wget write 1.txt

图：一个典型的 Linux 操作系统下的系统审计框架

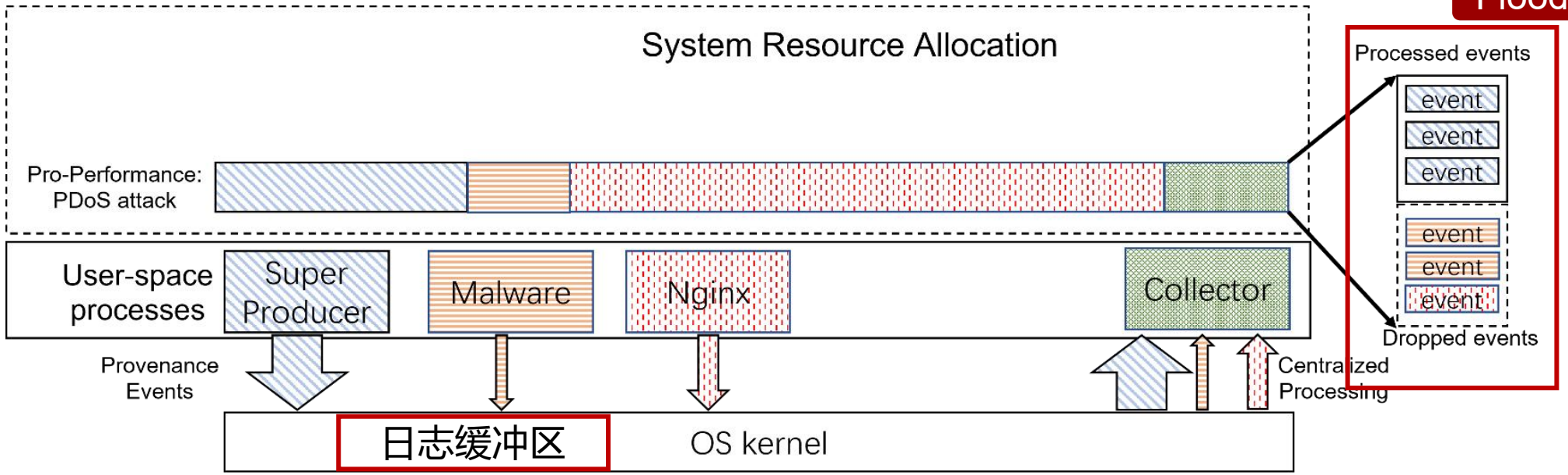
开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

研究问题：安全性与高开销之间的矛盾

系统日志本身存在被攻击的风险，需要添加昂贵的安全保护

大量系统资源

Flood Attack



Race Condition Attack

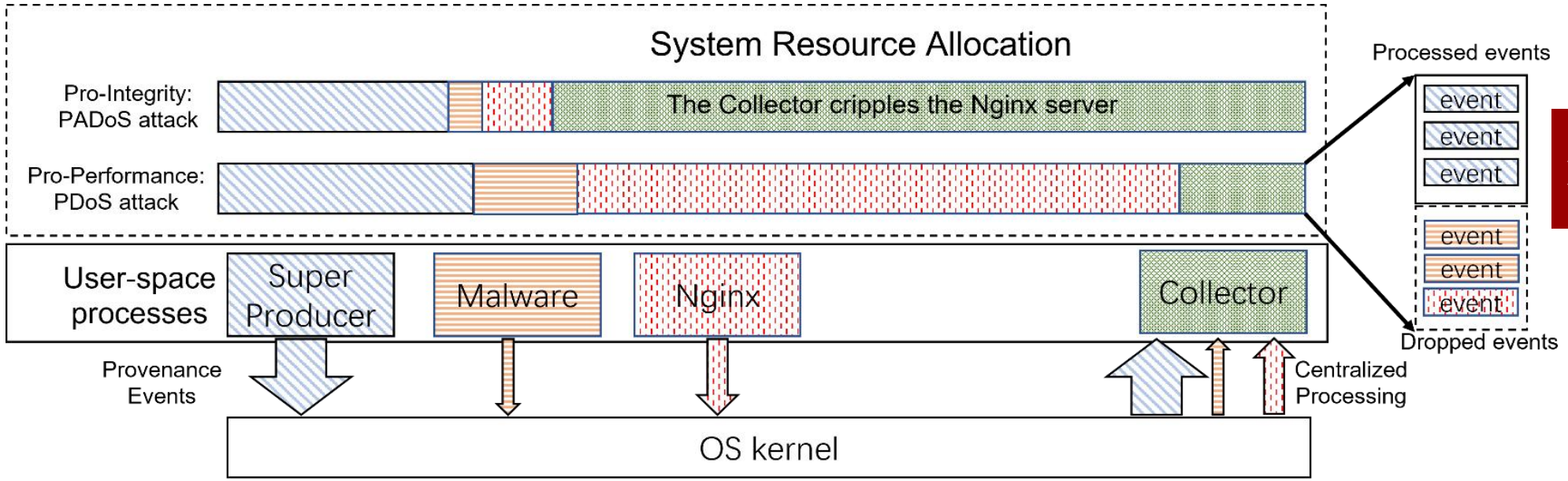
同步锁，加密

- Flood Attack：攻击者可以快速生成大量无效日志，占满日志缓冲区，造成后续日志丢失
- Race Condition Attack：攻击者可能会通过权限提升，插入内核模块，从而篡改内核缓冲区中的日志（缓存时间大于5ms），删除与上述攻击步骤有关的数据

开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

NODROP：软件优化的系统审计框架

- 借助系统审计框架的DoS攻击：如果不对采集器的资源进行限制，攻击者可以通过产生大量系统日志（超级生产者），使得采集器挤占系统内正常应用的资源，严重时导致系统崩溃
- 问题根源：现有方法采用一种集中式处理架构，破坏了操作系统中的进程间数据隔离



集中式处理

"Auditing Frameworks Need Resource Isolation: A Systematic Study on the Super Producer Threat to System Auditing and Its Mitigation"

Peng Jiang, Ruizhe Huang, Ding Li*, Yao Guo, Xiangqun Chen, Jianhai Luan, Yuxin Ren and Xinwei Hu

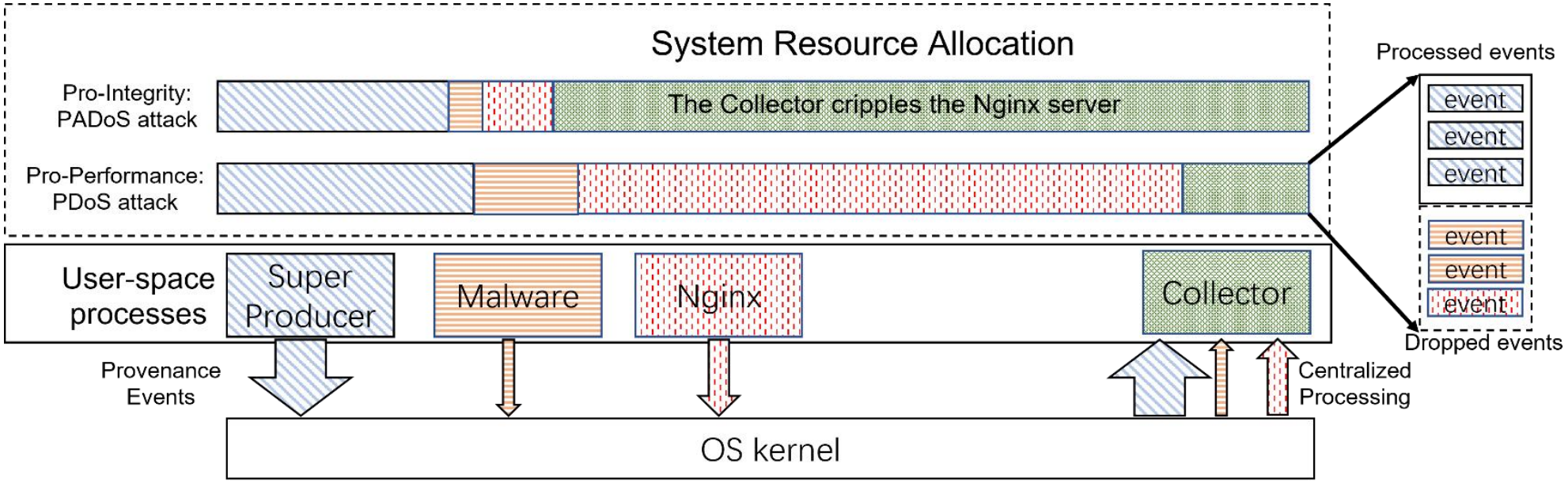
(**Usenix Security 23**)

开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

NODROP：软件优化的系统审计框架

- 解决思路：为审计日志提供进程级隔离
- 挑战：如何高效地实现隔离？
- 方法：将现有集中式的架构，转变为分布式的架构
  - 复用操作系统自身的进程间隔离机制
  - 在每个进程自己的地址空间内提供审计日志的处理逻辑

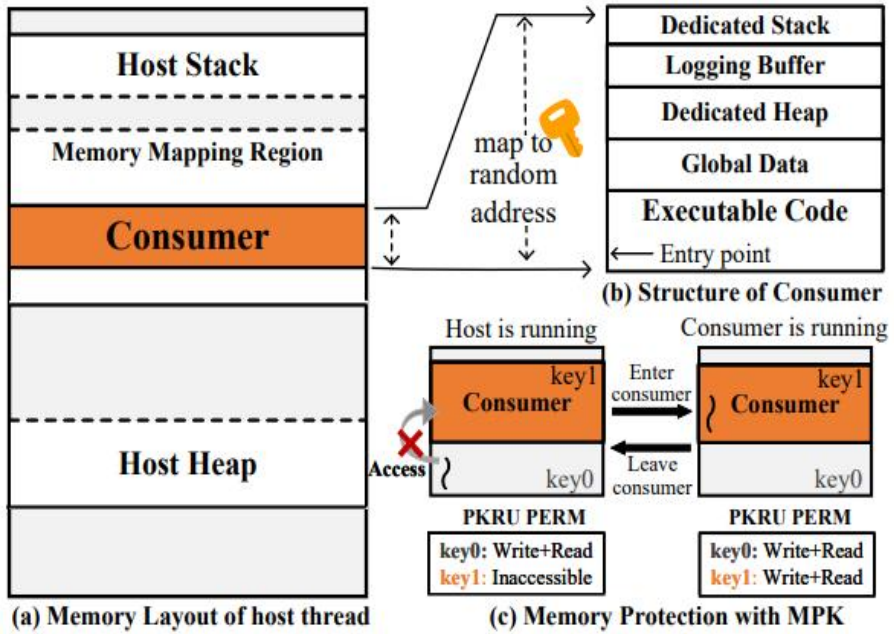
数据0丢失，性能低损耗



开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

NODROP的设计

- 基于**线程切片**的高效隔离：
  - 将日志处理逻辑（消费者）注入到当前正在运行线程（宿主线程）的内存中
  - 在特定的时机upcall到消费者的入口点，开始对线程专用缓冲区中的日志进行处理
- 多重内存保护：
  - 通过地址随机化和内存保护秘钥（MPK）使得宿主线程以及处于同一个进程地址空间下的其他线程无法影响和攻击内存中的消费者



(a) Memory Layout of host thread (b) Structure of Consumer (c) Memory Protection with MPK

开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

NODROP运行工作流程

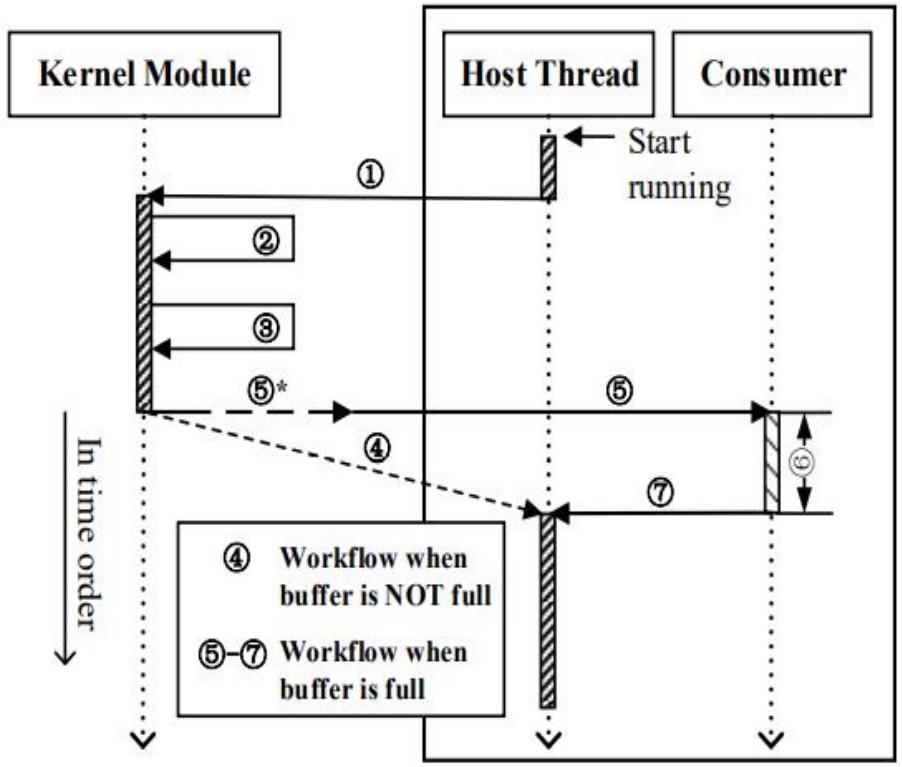
S1: 内核获取系统调用(①) 并执行(②). 系统调用日志被记录到当前进程的缓冲区中(③).

S2: 缓冲区日志停留时间超过5ms时: 返回当前线程(④). 缓冲区满或线程退出时: 跳转到日志处理逻辑处理（Consumer）(⑤).

S3:日志处理逻辑被动态插入到每个运行中的线程中(⑤*).

S4:日志处理逻辑处理系统日志（⑥).

S5: 控制权返回到当前主线程(⑦).

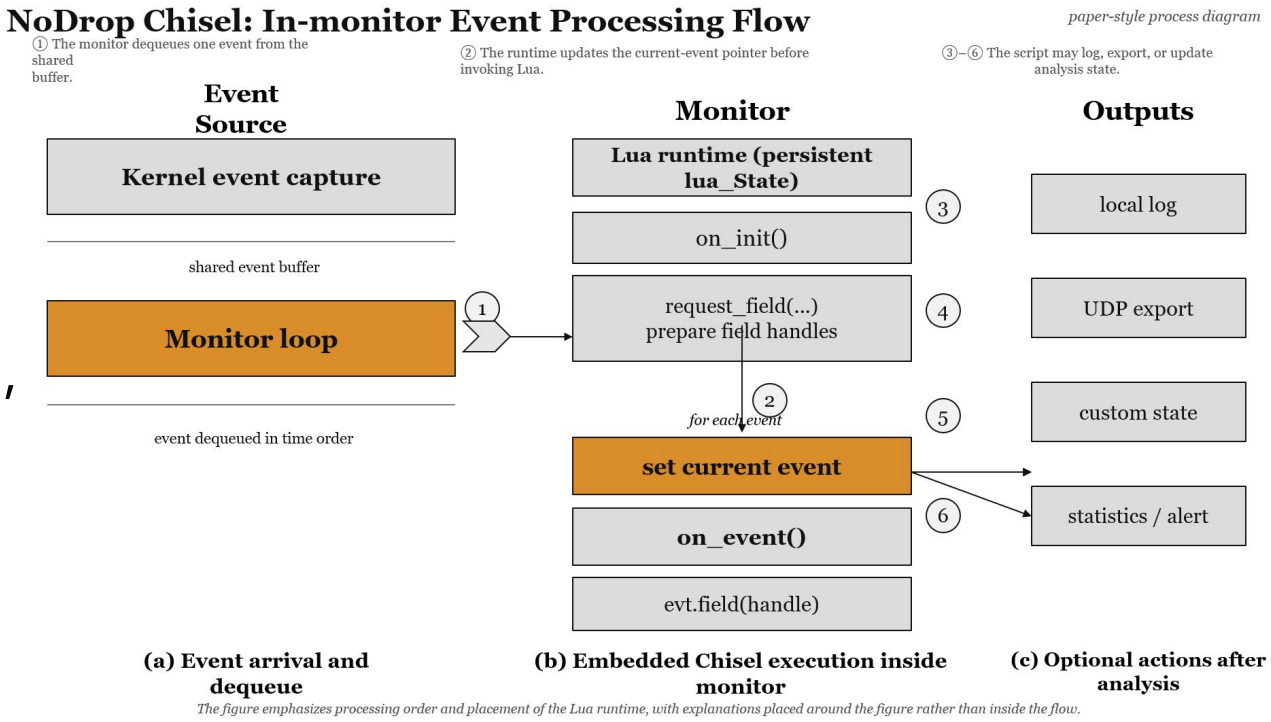


开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

NODROP：软件优化的系统审计框架

■基于监控器内嵌执行的事件处理：

- 将 Lua runtime 常驻在 monitor 内部，由 monitor loop 按时间顺序从事件缓冲区取出事件，在每次回调前设置 current event 指针，再 upcall 到 on_event() 入口执行分析逻辑。

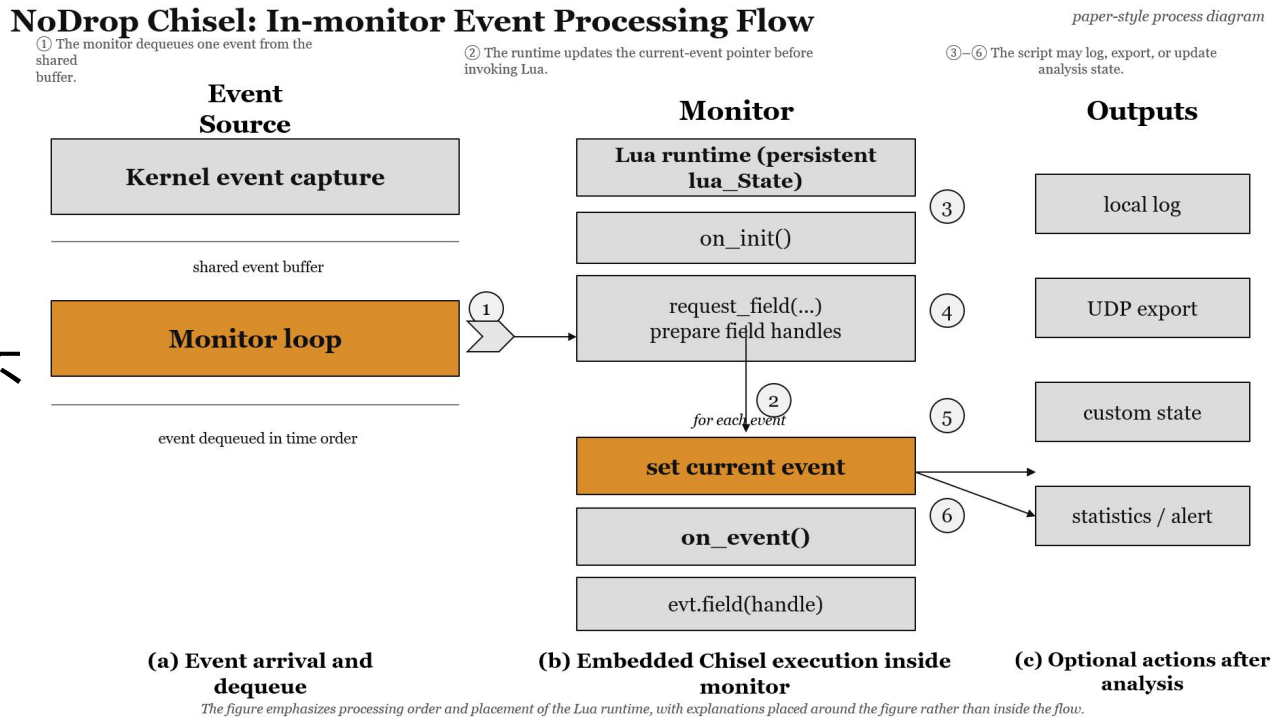


开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

NODROP：软件优化的系统审计框架

■基于实例级运行时隔离：

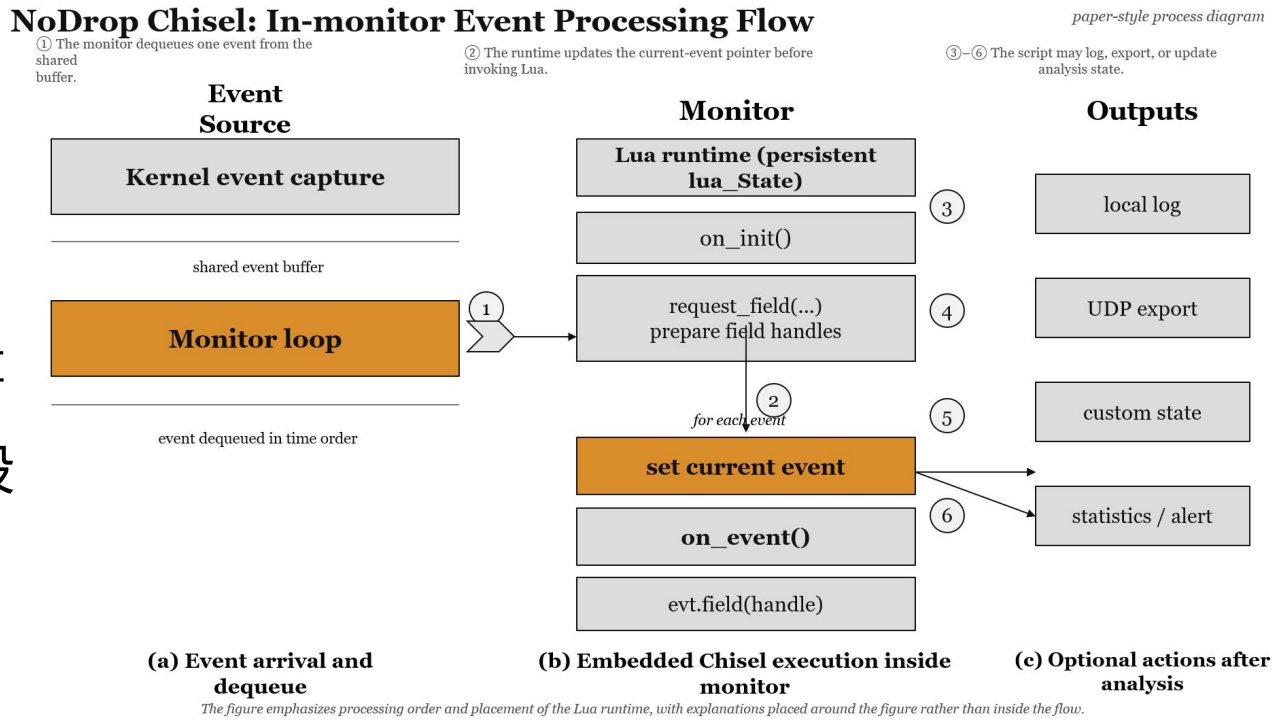
- 每个 monitor 实例独立绑定并常驻一个专属 Lua runtime事件仅在所属 monitor 内处理，不跨 monitor 共享运行时，从而避免上下文串扰和锁竞争。



开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

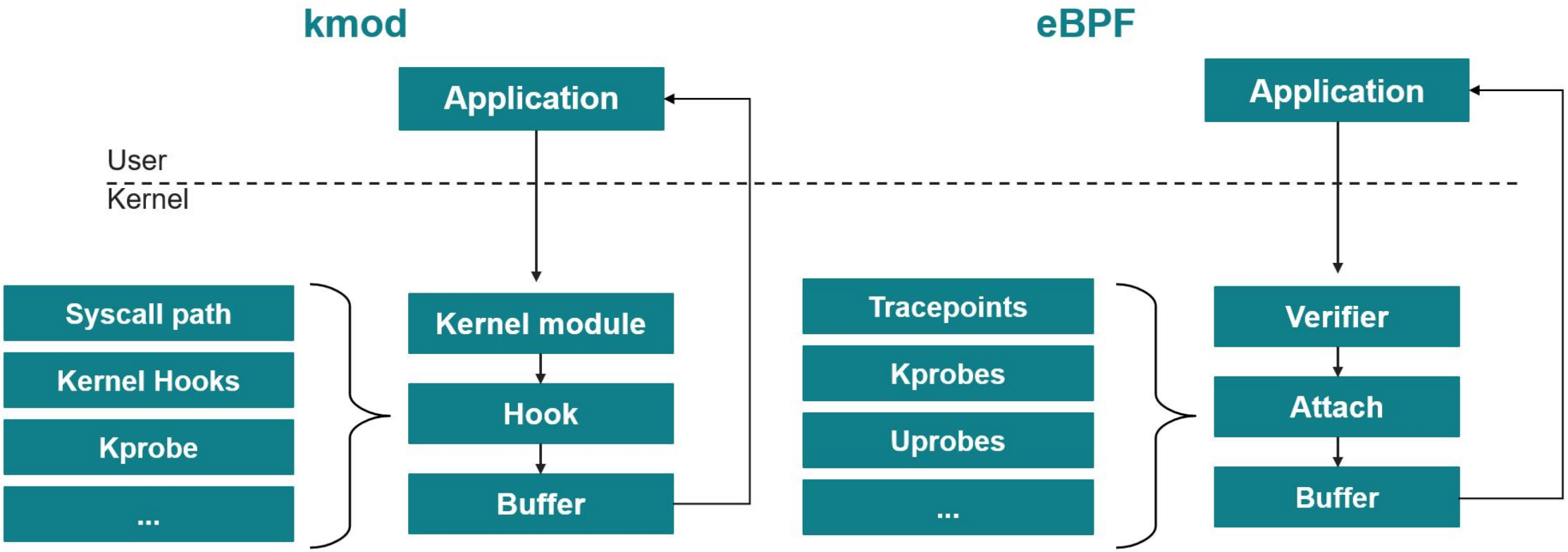
NODROP：软件优化的系统审计框架

- 可编程事件处理：
  - 将事件分析逻辑从固定代码路径中剥离出来，抽象为可动态装载的 Lua 回调；monitor 负责事件分发与执行上下文维护，脚本负责过滤、字段提取、状态更新和导出控制，从而在不修改 monitor 主体的前提下实现按需扩展的事件处理能力。



开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

NODROP：软件优化的系统审计框架



kmod：直接加载内核逻辑

eBPF：verifier校验后附着执行

开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

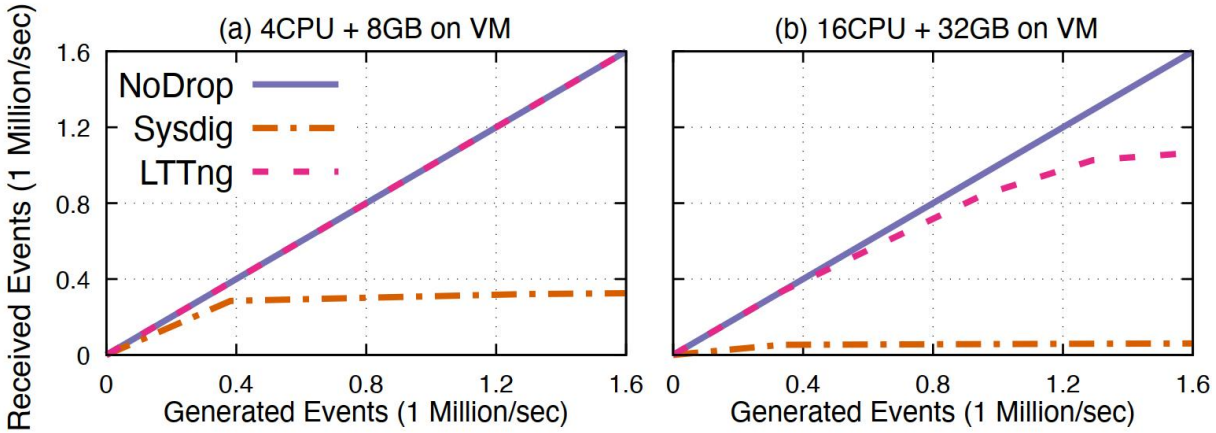
NODROP：软件优化的系统审计框架

对比维度	内核模块	eBPF
安全性	可能直接崩溃内核（无验证）	必须通过内核安全验证器检查
性能	加载耗时，但执行效率高	JIT编译后执行效率接近原生内核代码
可移植性	依赖特定内核版本，兼容性差	助CO-RE (Compile Once - Run Everywhere) 技术（如libbpf库），可实现跨内核版本兼容
灵活性	修改或加载新版本通常需要卸载旧模块再加载新模块	动态加载/卸载，实时生效

开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

NODROP：软件优化的系统审计框架

➢ 实验验证1：防止日志丢失



图：虚拟机的两种核数配置下，在超级生产者不同工作负载影响下的日志丢失

	Sysdig	LTTng	Linux Audit	NODROP
Default	120/120	107/120	120/120	0/120
Cgroup	115/120	107/120	120/120	0/120

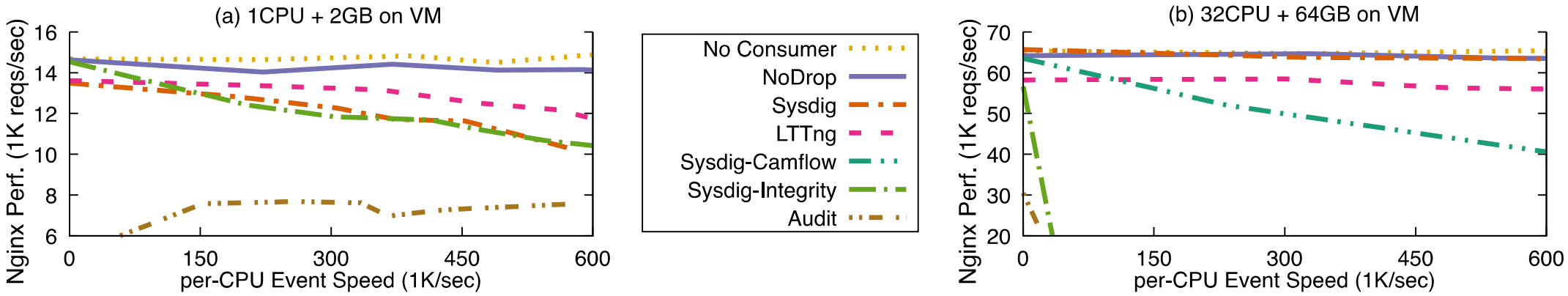
表：Flood Attack的成功攻击率 (成功次数 / 总次数)

- NODROP在16个核每秒产生160万条日志的**极端负载**下，依然**没有丢失**事件
  - 丢失情况最好系统审计框架丢了40%

开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

NODROP：软件优化的系统审计框架

➢ 实验验证2：避免应用程序被拖慢



■ NODROP能够防御借助系统审计框架的DoS攻击

- 当超级生产者在占用固定CPU资源的情况下，不断提升其日志生成速率，NODROP始终能保证其他应用程序的性能不受超级生产者日志生成速率的影响

开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

NODROP：软件优化的系统审计框架

➢ 实验验证3：降低运行时开销

- 即使没有超级生产者运行，NODROP也比SOTA(Sysdig)性能更好
  - NODROP没有引入额外的处理线程
  - 避免了处理逻辑所需要的进程调度
  - 避免了处理逻辑访问缓冲区时的跨核数据搬运

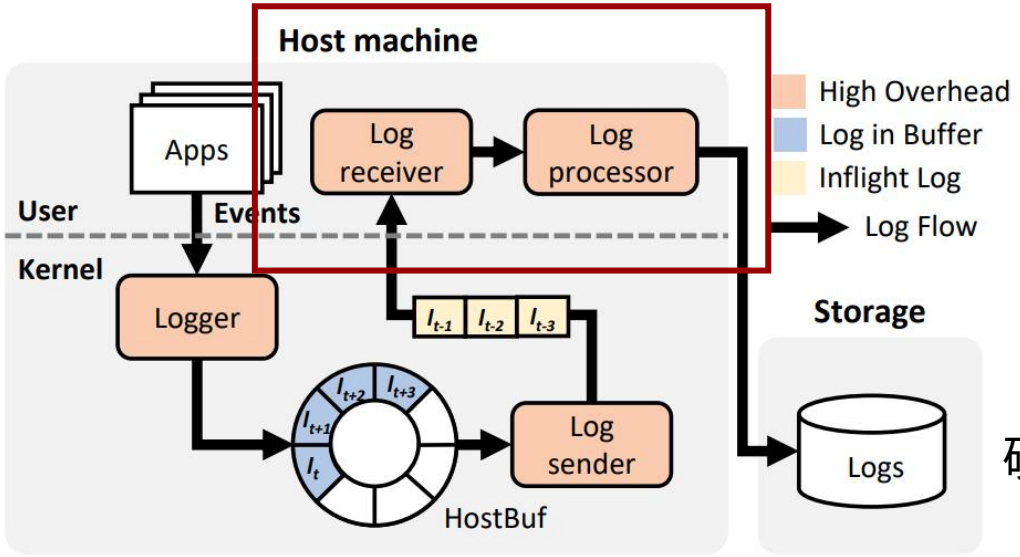
应用	系统审计框架	C1	C2	C3	C4	C5	C6	C7	C8
Nginx	NODROP	9.80	5.00	2.40	3.60	11.35	8.84	3.37	4.84
	Sysdig	55.30	16.30	12.10	5.50	37.64	21.20	9.50	7.20
	DIFF	**-29.30**	**-9.70**	**-8.60**	**-1.80**	**-19.10**	**-10.20**	**-5.60**	**-2.20**
Redis	NODROP	8.90	6.40	7.40	3.10	8.66	4.18	11.79	2.42
	Sysdig	21.00	14.10	13.50	5.00	21.00	16.40	15.60	5.70
	DIFF	**-11.10**	**-9.00**	**-7.10**	**-2.00**	**-10.20**	**-10.50**	**-3.30**	**-3.10**
Postmark	NODROP	25.50	28.20	20.20	19.10	30.60	35.77	27.57	20.65
	Sysdig	96.30	23.20	18.40	8.60	95.80	23.20	16.50	13.50
	DIFF	**-36.00**	**4.10**	**1.50**	**9.70**	**-33.30**	**10.20**	**9.50**	**6.30**
Django (Python)	NODROP	1.30	1.60	1.00	2.00	1.30	1.60	0.50	-0.20
	Sysdig	1.10	1.20	0.20	2.30	1.10	1.40	0.10	0.30
	DIFF	0.30	0.50	0.80	-0.30	0.20	0.20	0.40	-0.50
http (Golang)	NODROP	14.10	6.20	2.40	2.20	14.66	6.19	4.20	2.71
	Sysdig	78.90	10.60	4.40	2.20	65.70	11.90	4.10	2.20
	DIFF	**-36.20**	**-4.00**	**-1.80**	0.10	**-30.80**	**-5.10**	**0.10**	0.50
OpenSSL	NODROP	0.60	1.00	0.10	0.10	0.20	0.00	1.60	0.70
	Sysdig	0.60	0.40	0.50	0.10	0.20	0.20	1.70	0.60
	DIFF	0.10	0.60	-0.30	0.00	0.00	0.20	-0.10	0.10
7-ZIP	NODROP	0.30	1.20	0.40	0.80	1.20	0.80	1.10	0.70
	Sysdig	0.20	0.70	0.30	0.70	1.20	1.00	0.80	0.70
	DIFF	0.10	0.50	-0.10	0.10	0.00	-0.20	0.30	0.00
PostgreSQL	NODROP	7.05	6.40	4.72	3.80	10.20	8.80	6.10	4.70
	Sysdig	15.20	10.70	8.30	4.70	17.40	10.30	7.80	4.90
	DIFF	**-7.61**	-4.04	-3.40	-0.80	**-6.50**	-1.30	-1.60	-0.19

图：前两行显示了相对裸机的运行时开销，其中**较低的值**表示应用性能更接近裸机; 第三行显示了和 Sysdig 之间的相对开销，**小于 0 的值**表示性能优于 Sysdig

开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

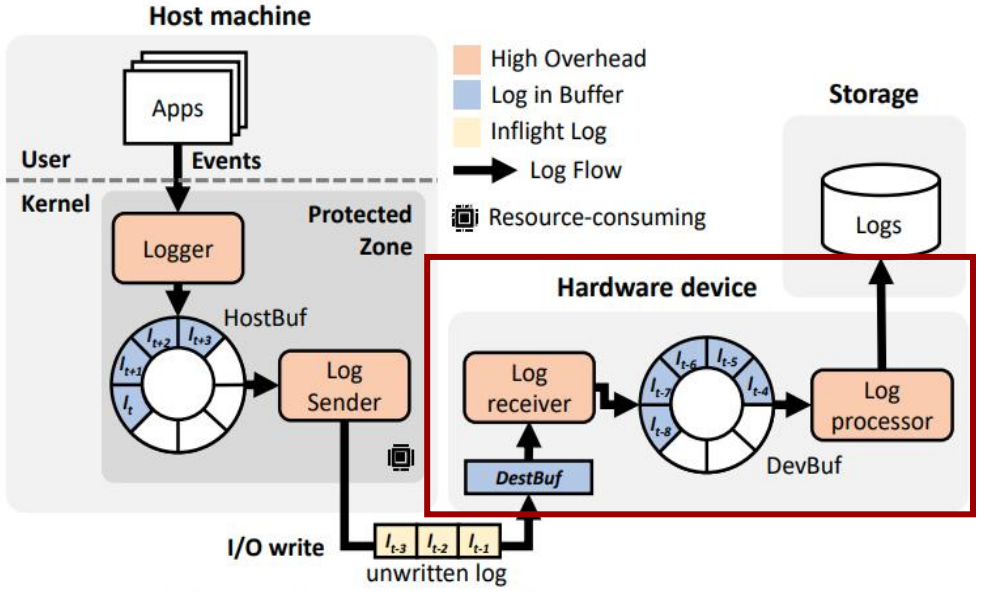
硬件辅助的系统审计框架

日志处理逻辑被卸载到外部硬件中



(a) Software-based auditing framework

硬件辅助

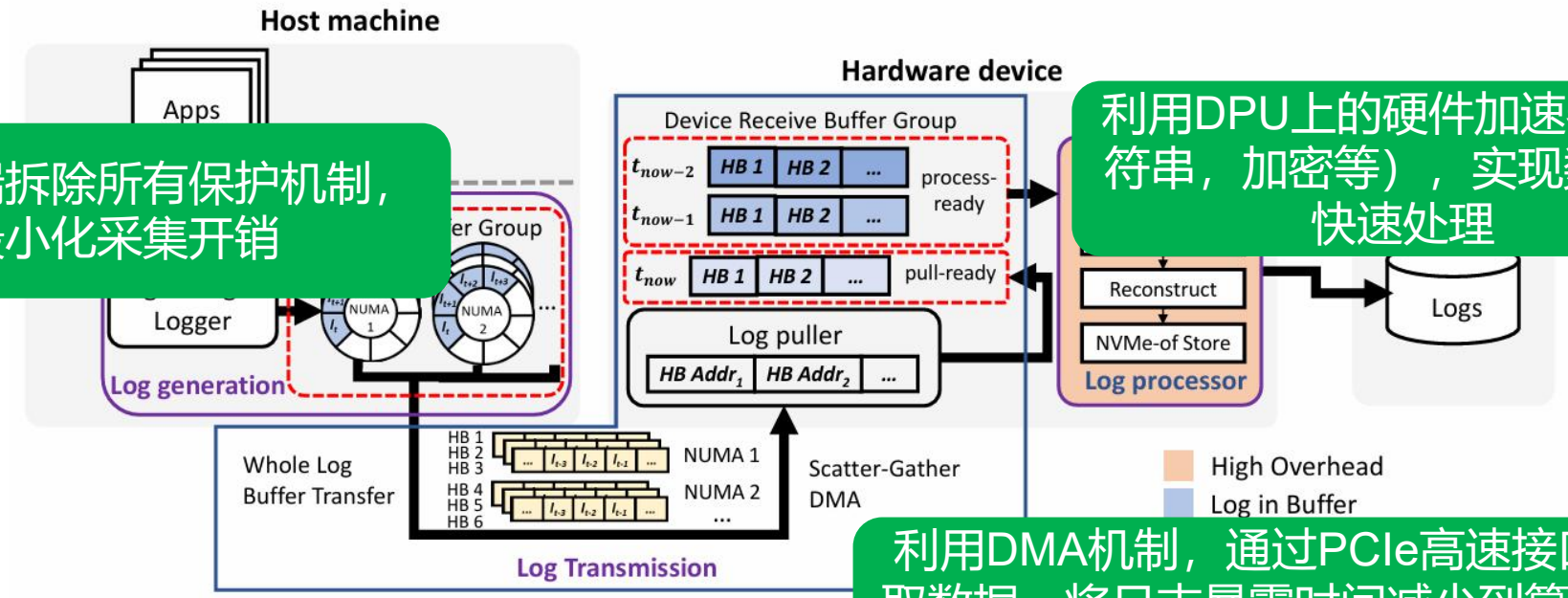


(b) Hardware-based auditing framework

开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

DPUaudit：基于DPU的系统审计框架

利用DPU的PCIe高速接口和加速引擎，显著减少日志的暴露时间



被监控端拆除所有保护机制，最小化采集开销

利用DPU上的硬件加速器（字符串，加密等），实现数据的快速处理

利用DMA机制，通过PCIe高速接口，快速读取数据，将日志暴露时间减少到篡改所需最小时间以下

"DPUaudit: DPU-assisted Pull-based Architecture for Near-Zero Cost System Auditing"

Peng Jiang, Hanlin Jiang, Ruizhe Huang, Hanwen Lei, Zhineng Zhong, Ding Li, Yuxin Ren, Yao Guo, Xiangqun Chen.

(IEEE HPCA 25)

开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

总结与展望

- 系统审计是终端检测防御的重要基础
- 目前系统审计面临着开销过高、安全性不足的问题
- 分别提出软件优化与硬件卸载方法，实现低开销，高安全的系统日志采集，可以分别适用于轻量级终端以及计算中心的云服务器中

开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

团队介绍

核心团队人员

李锭

北京大学

蒋鹏

东南大学

团队官网

https://di30617599.jzfkw.net/

开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

论文发表情况

“Auditing Frameworks Need Resource Isolation: A Systematic Study on the Super Producer Threat to System Auditing and Its Mitigation”
Peng Jiang, Ruizhe Huang, Ding Li*, Yao Guo, Xiangqun Chen, Jianhai Luan, Yuxin Ren and Xinwei Hu
(**Usenix Security 23**)

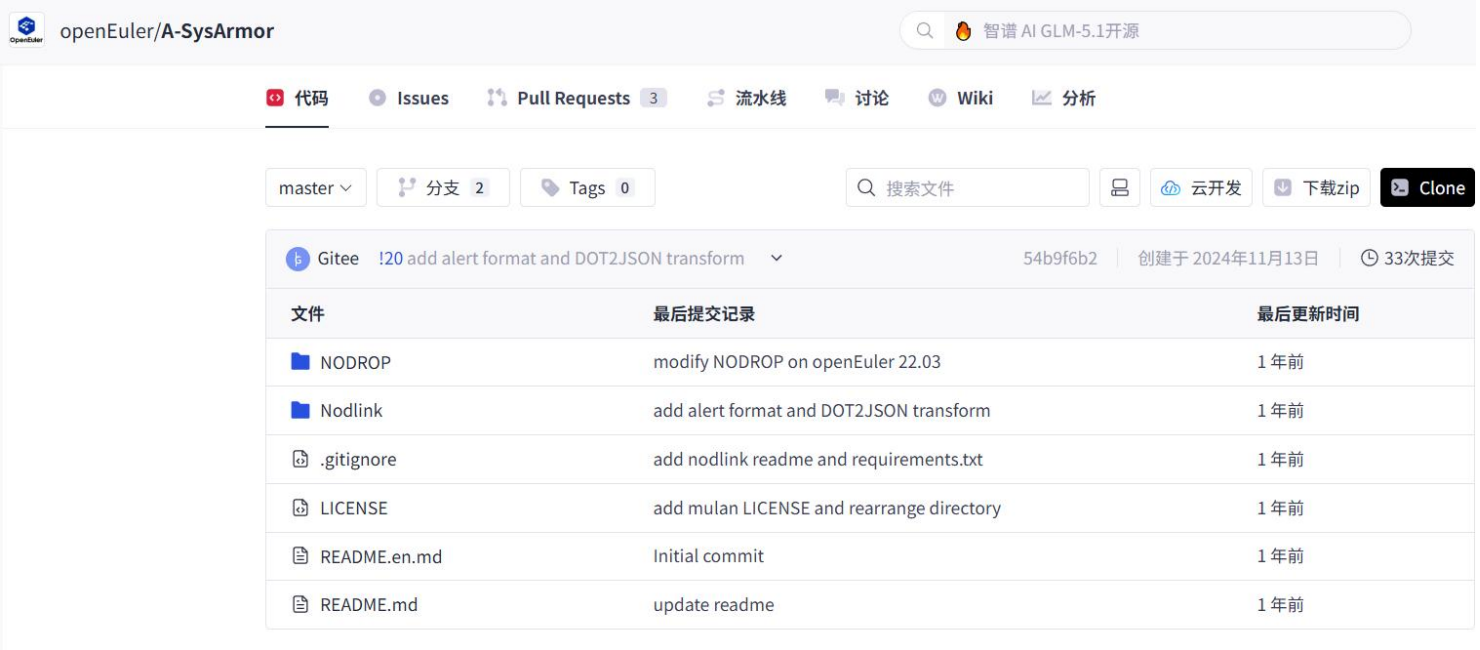
“NODLINK: An Online System for Fine-Grained APT Attack Detection and Investigation”
Shaofei Li, Feng Dong, Xusheng Xiao, Haoyu Wang, Fei Shao, Jiedong Chen, Yao Guo, Xiangqun Chen, Ding Li
(**NDSS 24**)

“DPUaudit: DPU-assisted Pull-based Architecture for Near-Zero Cost System Auditing”
Peng Jiang, Hanlin Jiang, Ruizhe Huang, Hanwen Lei, Zhineng Zhong, Ding Li, Yuxin Ren, Yao Guo, Xiangqun Chen.
(**IEEE HPCA 25**)

开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

开源情况

openEuler 开源： https://atomgit.com/openeuler/A-SysArmor/



开放原子开源基金会 OPENATOM FOUNDATION | OpenEuler

THANKS

开放原子开源基金会
OPENATOM FOUNDATION | OpenEuler